

IR Triage Report

Front Matter

ANALYST NAME: LOGAN NIPPERT
DATE: AUGUST 9, 2025
SOURCE: `/etc/modsecurity/crs/rules/REQUEST-911-BRUTE-FORCE.conf`
ALERT ID: `ZgUGhV1CEwAABx43AYAAAAAB`
SEVERITY: HIGH
DISPOSITION: Escalated

Initial Findings

This alert identified a **brute-force authentication attempt** targeting the WordPress login page. The activity resulted in the **compromise of multiple user credentials** and successful attacker login. This incident is assessed as a **true positive** with high confidence due to direct evidence of successful logins after repeated credential testing. The severity is determined to be **High** given the successful compromise of multiple accounts and the potential for further malicious activity within the WordPress environment.

Incident Summary

Incident activity was observed between **2025-04-10 15:42:22 UTC** and **2025-04-10 15:48:41 UTC**, spanning a total duration of approximately **380 seconds (6 minutes and 20 seconds)**.

Timeline of Key Events (UTC)

- 2025-04-10 15:42:22 UTC:** Initial brute-force attempt initiated against the WordPress login page (TCP Stream 18), identified by a "Hydra" user agent.
- 2025-04-10 15:42:28 UTC:** Attacker submits authentication form with credentials "elliot" and "c5G."
- 2025-04-10 15:42:37 UTC:** Attacker continues authentication attempts with credentials "elliot" and "c5G" across multiple ports.
- 2025-04-10 15:42:56 UTC:** Attacker continues authentication attempts with credentials "elliot" and "c5G."
- 2025-04-10 15:48:41 UTC:** Attacker submits authentication form with administrative credentials "admin" and "Triple10," followed by "admin" and "mrqwhyazrymy" (TCP Stream 595), marking the end of the observed attack activity.

Scope

The brute-force attack targeted the WordPress instance hosted on **192.168.100.2**. Multiple user accounts, specifically identified during authentication attempts as "admin" and "elliot," were targeted. Based on the initial findings, the attacker successfully logged in with at least two sets of compromised credentials. The role of these compromised accounts and the extent of their access within the WordPress environment are under further investigation, but they are recognized as valid credentials. There is no evidence of lateral movement beyond this host at this time.

Impact

The successful brute-force attack resulted in the **compromise of multiple valid user credentials** and **unauthorized access to the WordPress administration interface**. This represents a degradation of the security posture for the affected WordPress instance. The potential for data exposure or further malicious actions (e.g., website defacement, plugin manipulation, content injection) exists due to the attacker's login access. No known services were disrupted during the observed window of compromise, and no data exfiltration was observed.

MITRE ATT&CK TTPs Leveraged by the Adversary

The following MITRE ATT&CK techniques were observed:

- **Brute Force: Password Guessing (T1110.001)**: Repeated authentication attempts against the `/wp-login.php` endpoint.
- **Valid Accounts (T1078)**: Use of discovered valid credentials ("admin" and "elliott") to gain authenticated access.

Threat Intelligence Indicators

- **User-Agent String**: `Mozilla/5.0 (Hydra)`

Recommended Actions

Based on the investigation into the brute-force attack and successful authentication against the WordPress instance, the following actions are recommended to mitigate current risks, enhance preventative controls, and improve future detection capabilities:

IR-related actions for impacted infrastructure

- **Immediately reset passwords** for the compromised 'admin' and 'elliott' accounts. As a precautionary measure, consider initiating a forced password reset for all other WordPress user accounts.
- **Conduct a thorough forensic analysis** of the WordPress server (192.168.100.2) to identify any persistence mechanisms (e.g., web shells, malicious plugins), unauthorized modifications, or evidence of lateral movement post-compromise.
- **Review WordPress access logs for all activity immediately following the successful logins** to identify any actions taken by the attacker (e.g., content changes, user creation, plugin installation).

Prevention-related recommended actions for impacted infrastructure

- **Implement Account Lockout Policies (M1036)**: Configure the WordPress login page to enforce an account lockout policy after a defined number of failed login attempts to prevent brute-force and password guessing attacks. Consider integrating with a Web Application Firewall (WAF) or other perimeter controls to block risky authentication requests from suspicious IPs or anonymizing services.
- **Deploy Multi-Factor Authentication (M1032)**: Enable and enforce multi-factor authentication (MFA) for all WordPress user accounts, especially for administrative users, to add a critical layer of security against compromised credentials.
- **Strengthen Password Policies (M1027)**: Review and update the WordPress password policy to adhere to robust guidelines (e.g., NIST SP 800-63B recommendations) requiring strong, unique passwords for all users.

Prevention-related recommended actions for internal policies

- **User Security Awareness Training**: Incorporate lessons learned from this incident into regular user security awareness training, emphasizing the importance of strong, unique passwords and the risks of credential compromise.
- **Application Security Best Practices**: Establish or reinforce internal policies requiring the implementation of security best practices, including MFA and strong password policies, for all externally facing web applications.

Detection-related recommended actions for improved SOC flows

- **Enhance Brute-Force Detection Rules (DS0015 Application Log & DS0002 User Account):** Refine existing SIEM detection rules to specifically monitor WordPress authentication logs for a high volume of login failures targeting valid accounts (DS0015). Additionally, implement analytics (DS0002) to detect multiple failed authentication attempts across various WordPress user accounts, indicating potential widespread password guessing. Further enhance these rules by correlating failed login attempts with any subsequent successful logins from the same source IP within a defined timeframe, and by incorporating specific user-agent strings (like "Hydra") associated with known attack tools.
- **Ingest Comprehensive WordPress Logs:** Verify that all relevant WordPress logs, including authentication attempts (success and failure), user activity, and plugin/theme changes, are comprehensively ingested into the SIEM for centralized monitoring and analysis.
- **Update Incident Response Playbook:** Revise the "Web Application Brute Force" and "Credential Compromise" incident response playbooks to include specific steps for WordPress environments, such as checking for common WordPress attack indicators and post-exploitation artifacts.